# DARTS-128（1–2b 模式）密钥恢复：公开可重放的双分支判定与 hint 通道

GLM-5.3 Max JY Liu

2026 年 10 月 19 日

**摘要**

DARTS-128 是 NICCS 首轮征集的格签名候选。CryptHash 论坛其后发布了一次模式修订，把签名响应中的共享符号因子从 $(1-b)$ 改为 $(1-2b)$。本文报告对该修订版参考实现的密钥恢复：修订迫使验证侧采用 $\bar{A}z_1 \pm \hat{q}c\beta$ 双分支（验证方不知 $b$），而分支判定可以被任何观察者公开重放——真分支恒匹配，假分支在 $\pm c\alpha$ 不跨量化边界时同样匹配（概率 $(1-2^d/q)^\tau \approx 0.79$）。于是 200 万条公开签名中 21.0% 携带 **零误差**的 $b$ 标签。以这些标签驱动两条独立的最小二乘通道（$\zeta$ 域标记最小二乘与 hint 通道），再以公钥恒等式收尾，我们精确恢复 $(s_0, s_1, e)$ 全部 1536 字节，与真值逐字节一致；未修改参考验证器下伪造 20/20 接受，三组阴性对照全部拒绝。完整技术报告（14 页）见同目录 `DARTS_1-2b_ 攻击报告.pdf`。

**Abstract.** DARTS-128 is a lattice signature candidate of the NICCS first round, later revised by the CryptHash forum from a $(1-b)$ to a $(1-2b)$ shared sign factor. The revision forces the verifier into a two-branch test $\bar{A}z_1 \pm \hat{q}c\beta$, and this branch decision is publicly replayable: the true branch always matches, while the false branch also matches whenever $\pm c\alpha$ does not cross a quantization boundary (probability $(1-2^d/q)^\tau \approx 0.79$). Consequently 21.0% of 2 million public signatures carry a zero-error $b$ label. Two independent least-squares channels driven by these labels—a $\zeta$-domain tagged solve exploiting the negacyclic diagonalization, and the hint channel—together with a public-key identity, recover $(s_0, s_1, e)$ exactly (all 1536 bytes, byte-identical to the truth). Forgeries pass the unmodified reference verifier 20/20; all three negative controls are rejected.

## 1 对象与授权

审计对象为 DARTS 提交包参考实现按 $(1-2b)$ 修订后的版本；修订涉及 `sign.c`（三处）、`poly.c`、`poly.h` 与 `fft.c` 的一处整型修复，原文件以 `*.orig_1b` 备份，逐文件 sha256 与批次清单在 `artifacts/`。研究在提交方授权的自查场景下进行；攻击输入仅为公钥与公开签名，秘密密钥仅用于事后评分。评分与攻击严格分离：`attack.py` 的真值参数为可选评分输入，攻击在完全不接触真值的模式下运行，本报告全部攻击结果均在该模式下复现；`gen_dump` 输出流的首字节为评分侧车（记录真实 $b$），攻击代码不读取。

## 2 泄露的来源：一个公开可重放的判定

$(1-2b)$ 修订的本意是修补共享符号因子的分布缺陷，但它把验证方程变成了验证方对每个候选符号的重放哈希：$\bar{A}z_1 + \hat{q}c\beta$ 或 $\bar{A}z_1 - \hat{q}c\beta$。验证方不知道 $b$，只能两个都试；而 “哪个分支匹配” 这件事本身是公开信息。三类匹配结果（仅 $+$、仅 $-$、双匹配、无匹配）中：

- **仅单侧匹配**的签名给出 $b$ 的确定标签。200 万条中 420,453 条（21.0%），准确率 100.0000%——不是统计意义上的高准确率，是**零误差**：单侧匹配在结构上排除另一个 $b$ 值。
- 双匹配样本经生成测度的镜像对合 $(y, b, \text{coins}) \mapsto (-y, 1-b, \text{coins})$ 严格证明 $P(b{=}0 \mid \text{双匹配}) = 1/2$，一阶统计无信息（实测 49.9%/50.1%，$1.58 \times 10^6$ 条）——完整证明见 14 页报告 §6。

# 3 恢复路线

## 3.1 R1：$z_1$ 通道的 $\zeta$ 域标记最小二乘 $\to s_0, s_1$

$z_1 = y_1 + (-1)^b (s_c \star c)$，$y_1$ 为超球新鲜噪声。标签已知时这是一个带符号的线性回归，但 $R_q = \mathbb{Z}_q[x]/(x^n+1)$ 的乘法矩阵是**斜循环**的——直接套循环自相关会使信号完全相消（我们实测过：真臂与硬币臂 rms 相同）。修复是精确的：负循环在 $\zeta_k = e^{i\pi(2k+1)/n}$ 基下对角化，每条签名做 $2n$ 点 FFT、逐频点除法，复杂度线性于签名数。`attack.py selftest` 内置与稠密最小二乘的自检（一致到 $10^{-14}$）。

球拒绝采样带来一处必须处理的系统效应：$\|y\|$ 紧贴球半径（$d = 1536$ 时标准差 $B/d \approx 3.9$），双球拒绝在 $\langle y, sc\rangle$ 方向构成近半空间截断，实测 $\mathbb{E}[y \mid \text{acc}, b] = -0.63 \cdot (-1)^b \cdot sc$——标记最小二乘估计到的是 $\alpha = 0.37$ 倍缩放的信号。我们给出盲修正：矩估计 $\mathbb{E}[\hat\beta^2] = \alpha^2 \cdot 0.3 + \sigma^2$（0.3 为三元秘密二阶矩，$\sigma$ 取硬币臂），实测 $\hat\alpha = 0.367$，对真值 0.364。修正后加数据即可精确四舍五入。200 万条下 $s_0$、$s_1$ 各 512/512 精确（rms 0.12）。

## 3.2 R2 与 R2b：hint 通道与公钥恒等式 $\to e$

hint 通道给出独立的第二条路线：

$$h \cdot W \;\approx\; y_2 + (-1)^b (e \star c) - (1-2b)\, c, \qquad W = q/2^d,$$

居中观测 $o = (-1)^b \cdot h \cdot W + c = (e \star c) +$ 对称噪声，同套标记最小二乘直接估计 $e$。$h$ 的 mod-$2^d$ 环绕（`poly_compress` 的掩码在 $q$ 边界附近产生 ±1020 编码符号）按模重居中即可还原真实小差值——编码器的边缘区间本为此设计，对攻击者同样透明。

hint 通道先到 511/512；最后一处由公钥恒等式收尾：

$$e \;=\; \hat q\, \beta - (A_0 s_0 + A_1 s_1).$$

全解一致性 razor：$s$ 精确当且仅当 $e \in \{-1, 0, 1\}^{512}$。至此 $(s_0, s_1, e)$ 全部 1536 字节与真值逐字节一致。

## 3.3 伪造与阴性对照

恢复密钥 + 任取 $K$，未修改参考签名器/验证器下 20/20 接受。阴性对照三组：硬币符号臂（退化噪声，无恢复）；篡改 $e$ / 篡改签名 / 错误 pk（全部拒绝）。伪造闭环与对照在 `forge.c` 中端到端。

| 项 | 结果 |
|---|---|
| 干净标签 | 420,453 / 2,000,000（21.0%），准确率 100.0000% |
| $s_0$（$z_1$ 通道 LS） | 512/512 精确（rms 0.12） |
| $s_1$（$z_1$ 通道 LS） | 512/512 精确 |
| $e$（hint 通道 LS + 公钥恒等式） | 511/512 → 恒等式修正 → 精确 |
| 伪造 | 20/20 接受（未修改参考验证器） |
| 阴性对照 | 三组全部拒绝 |

## 4 恢复程度

恢复的是**完整秘密钥**而非等价钥：DARTS 的密钥没有 BiT 式的验证等价自由度，逐字节比对即验收。

## 5 下一步工作

1. **低数据量化**。当前 $2\times10^6$ 是充分条件；干净标签率 21% 决定了标签噪声底，缩放修正已知（$\kappa \approx 0.63$ 的条件化收缩有盲修正），系统的 $N$–精度曲线与自适应停止准则（`adaptive_stop*.sh` 已有雏形）可以把数据量压到什么程度，是 `低数据攻击方案.md` 的主题，方案按数量级减小设计了三档。
2. **模糊签名的利用**。双匹配样本一阶无信息（§2），但其条件分布仍依赖 $(s, e)$ 与量化边界的相对位置——EM 式软标签在实测中发散（校准后 LLR 均值 0.7、后验翻转率 28%，根因是拒绝采样条件化收缩同样压缩了模糊签名的双峰似然），这条路已被数据否定，记录在此防止重复投入。
3. **迁移**。任何 “验证方必须枚举离散未知量” 的修订都天然产生公开可重放判定；DARTS 案例的机理（分支匹配集而非单分支判定、斜循环域的正确对角化、球拒绝收缩的盲修正）对同类修订具有直接参考价值。

## 6 复现指南

```
bash code/run_all.sh                # SMOKE=2000 全流程冒烟 / NS=500000 完整
python3 code/attack.py selftest     # zeta 域求解器 vs 稠密 LS 自检
```

`artifacts/` 含攻击日志、批次清单与公开输入样本（pk、原始与重放 dump、恢复的 hint）；评分真值文件不入库（可由 `gen_dump` 以记录的种子与批次参数再生，参数见 `artifacts/attack_log.txt` 与 14 页报告 §7）。修改后参考实现的构建流程与逐文件 sha256 见报告参考文献一节。

## 参考文献

[1] L. Ducas, A. Durmus, T. Lepoint, V. Lyubashevsky. *Lattice Signatures and Bimodal Gaussians*. CRYPTO 2013（ePrint 2013/383）.

[2] V. Lyubashevsky. *Fiat–Shamir with Aborts*. ASIACRYPT 2009; EUROCRYPT 2012.

[3] Z. Xiong, M. Wang. *Design-Level Cryptanalysis of the ICCS NGCC Round-1 Public-Key Candidates*. ePrint 2026/2232.

[4] DARTS 提交包：NICCS 首轮数字签名候选（DARTS-128 参数集，2026-09-20 归档版本）与 CryptHash 论坛 $(1-2b)$ 修订说明.